FRAUD READINESS · COMPREHENSIVE

Fraud Readiness Strategy and Control Blueprint

Fictional Retail Group (extensive unanswered information)

Assessment reference FX-P5

12 November 2026

Confidential. Prepared for the management of Fictional Retail Group (extensive unanswered information).

Fictional prototype for MK review. The organisation is fictional, calculated figures are labelled test results, and this is not a customer report or a certified paid report.

EXECUTIVE DIAGNOSIS

The group's framework stops short of its operations, and the first step is to establish what its own functions know

On its own answers, the group has the core controls in place for 46 of the 106 fraud scenarios that apply to it, a core control reported as a gap in 58, and core answers outstanding for two more. In fraud governance, finance and banking, and detection and response, every core control is reported in place. In third parties, people and payroll, customers, assets and stock, and digital channels, almost every core control is reported as a gap.

MK's reading is that the group has built the central parts of a fraud programme and has not yet carried them into the operations. Ownership is assigned, finance and banking controls are described as working, and concerns can be reported and investigated. The controls that would prevent and detect fraud inside the processes, where suppliers and staff are paid, customers receive credit and refunds, stock is held and instructions arrive, are largely absent.

What distinguishes this assessment is the information behind it. Seven questions put to the functions that run these processes came back as "not known", from five functions. The risk function could not say whether process owners take part in the risk assessment or whether it is updated when the business changes; payroll could not say whether its data is analysed; finance could not say whether customer payments are matched to invoices; and sales could not say where refunds are paid. Nothing is concluded from these answers, but they show that in several places the people closest to a control cannot describe it.

Four themes carry the diagnosis: the unknowns inside the functions, the framework that has not reached the operations, a verification weakness that recurs across four areas, and the absence of independent review over procurement and payroll. They interact. Where a function does not know how its control works, it cannot notice when the control fails; where requests are accepted on the requester's word, the failure is easy to induce; and where nobody looks across procurement or payroll, a resulting loss would be found by a supplier, a customer or a whistle-blower rather than by the group.

The exposure is concrete. A supplier's bank details can be changed and confirmed through the fraudster's own number, credit can be granted on documents checked only on appearance, refunds below a threshold can be raised and approved by the same person, and an employee in a sensitive role that was never identified may never hand over their work.

Leadership's priorities follow. In the first thirty days, every outstanding question should be assigned to a named person and answered or recorded as an open item, every operating area should have an accountable executive, and the order of work should be decided on explicit factors. Over the following two months, the priority controls should be designed and put to work: supplier bank changes confirmed through details on file, a call-back that holds whatever a caller appears to be, the monthly senior review of supplier payments, verification of credit applications with their source, and block leave for every sensitive role. By twelve months, each should have met its measure over a full cycle and the board should be receiving status on every area and every open question.

WHAT THE ASSESSMENT ESTABLISHES

CALCULATED TEST RESULT

55.1 of 100 TEST FIXTURE

The arithmetic result of the answers under the method's scoring frame, shown for traceability. It carries no band.

UNRESOLVED INCONSISTENCIES

None found

None found in the 1 pair of answers compared. Most related practices were not asked, so this is not a finding that every answer is consistent.

PROVISIONAL MANAGEMENT INTERPRETATION

58 with a control reported as a gap

On its own answers, the organisation reports the core control in place for 46 of the 106 fraud scenarios that apply; 2 cannot yet be read because answers are outstanding; and 58 have a core control reported as a gap.

APPROVED READINESS CONCLUSION

None issued

MK states its readiness conclusion here under its approved readiness method. Until then the report sets out what the answers establish.

The four statements are kept separate: the calculated result is arithmetic, the inconsistencies and the interpretation come from the organisation's own answers, and the readiness conclusion is MK's.

SCOPE AND ANALYTICAL BASIS

This blueprint interprets the group's own answers and designs the response; it does not verify that controls operate

The analysis rests on answers given by the group's respondent and the functions to which questions were referred, read against MK's fraud scenarios and controls. It covers 106 fraud scenarios across ten areas. Answers given as "not known" are reported as outstanding and are never treated as weaknesses or as controls in place. MK has not examined documents, interviewed staff or tested any control, and where the report names a record, it is a record management should keep.

The blueprint's value lies in what it does with the answers: it reads them together, draws them into themes, traces how the weaknesses could combine into fraud, and designs the controls, operating model, decisions and programme that would close them. Independent examination of whether controls operate belongs to MK Advisory, which is scoped and priced separately.

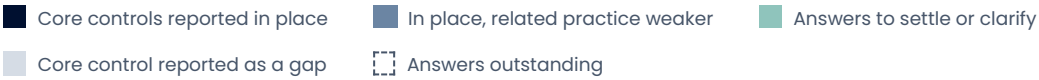
READINESS PROFILE

The centre holds, the operating areas are open, and the unknowns sit in both

In three areas every core control is reported in place: fraud governance and accountability, finance, banking and financial reporting and detection, speak-up and response. In five areas nearly every core control is reported as a gap: third parties and supply chain, people, payroll and insider risk, customers, revenue and products, assets, cash and inventory and digital, cyber-enabled and identity fraud. The fraud risk assessment would sit with the central areas but for questions its own function could not answer.

READINESS PROFILE: FRAUD SCENARIOS BY AREA

AREA	SCENARIOS THAT APPLY	CORE CONTROLS IN PLACE	TEST FIGURE
Fraud governance and accountability		12 of 12	90.0
Fraud risk assessment		5 of 6	90.0
Ethics, integrity and anti-corruption		9 of 10	81.0
Third parties and supply chain		0 of 13	19.3
People, payroll and insider risk		0 of 11	26.4
Finance, banking and financial reporting		12 of 12	92.5
Customers, revenue and products		0 of 10	25.0
Assets, cash and inventory		0 of 10	21.1
Digital, cyber-enabled and identity fraud		0 of 14	18.6
Detection, speak-up and response		8 of 8	86.7



Each bar shows the fraud scenarios in the method that apply to the organisation in that area, by what its answers report about the controls that stop them. Areas appear in the method's order. Test figures are the calculated result for each area, shown for traceability; they are not scores and carry no band.

The open areas hold most of the scenarios, with 14 gaps in digital channels, 13 in third parties and 11 in people and payroll. The outstanding answers fall in risk assessment, payroll, customers, assets and the speak-up process, so the unknowns are not confined to the open areas; they also limit how far the central framework can be relied on.

SYSTEMIC THEMES

Four themes explain the position, and the first determines how far the others can be addressed

The themes below draw the answers into a management view. The map shows where each appears, and the discussion explains how they interact.

WHERE EACH THEME APPEARS

AREA	Several functions do not hold answers about their own controls	The fraud framework is in place at the centre but has not reached the operating processes	Instructions that move money or change identity are accepted on the requester's word	Independent assurance examines high-risk processes
Fraud governance and accountability				
Fraud risk assessment	●			
Ethics, integrity and anti-corruption				
Third parties and supply chain		●	●	●
People, payroll and insider risk	●	●	●	●
Finance, banking and financial reporting				
Customers, revenue and products	●	●	●	
Assets, cash and inventory	●	●		
Digital, cyber-enabled and identity fraud		●	●	
Detection, speak-up and response	●			

A mark shows an area in which the answers contribute to the theme.

ACROSS THE ORGANISATION

Several functions do not hold answers about their own controls

The 7 questions answered “not known” concern ordinary, operational facts: whether process owners take part in the risk assessment, whether it is refreshed when the business changes, whether payroll data is analysed, whether customer payments are matched to invoices, where refunds are paid, whether the asset register is checked physically and whether the risk of retaliation against a reporter is assessed.

Each is treated as outstanding. Together they suggest that, in several processes, fraud controls are understood at the centre rather than by the people who run the process, which is consistent with the second theme. The practical consequence is that the group cannot yet rely on these controls, and it cannot design their replacements without knowing what already exists.

ACROSS THE ORGANISATION

The framework at the centre has not been carried into the operating processes

Governance, finance and detection are reported as complete, and the five operating areas as almost entirely open. The framework establishes who owns fraud risk and how concerns are handled; it does not stop a supplier being paid into the wrong account or stock leaving a store. Those outcomes depend on controls inside processes the centre does not run.

The response is organisational first: the executives who run procurement, payroll, customers, stock and digital channels should own the controls in their processes, with the centre setting the standard and checking that it is met.

ACROSS THE ORGANISATION

The same verification weakness recurs across suppliers, payroll, customers and digital channels

Across third parties and supply chain, people, payroll and insider risk, customers, revenue and products and digital, cyber-enabled and identity fraud, 13 practices that would verify a request through a route the requester does not control are reported weaker than in place. Supplier bank changes are confirmed through details in the request, a familiar voice is accepted, customer and employee changes are not consistently verified, and credit documents are checked on appearance.

Most payment diversion and impersonation succeeds by supplying the confirmation a process asks for. Because the weakness is shared, so is the remedy: verification through details already held, by a channel the requester did not choose, designed once and applied everywhere.

THIRD PARTIES AND SUPPLY CHAIN · PEOPLE, PAYROLL AND INSIDER RISK

No independent review examines procurement or payroll

Independent review of procurement and of payroll are reported weaker than in place across third parties and supply chain and people, payroll and insider risk. The senior review of supplier payments is agreed but not working, the payroll review looks only at totals, and payroll could not say whether its data is analysed.

Independent review is what would reveal both the controls that do not operate and the functions that do not know. In its absence, the themes reinforce one another, and the programme in this report addresses them together: answers first, ownership next, a shared verification standard, and independent review of the processes that move the most money.

FINDINGS

Seven findings show how the themes appear in the processes that move money, goods and credit

The findings are the scenarios through which each theme appears most clearly: within each theme, the scenario with more core controls reported absent, or with the most related practices also reported weaker. They follow the method's order of areas, which is not a ranking; The full register is in the supporting workbook.

THIRD PARTIES AND SUPPLY CHAIN

Supplier bank changes are confirmed through details the fraudster can supply

Changes to supplier bank details are confirmed, but sometimes through contact details taken from the request, and a follow-up call from someone who sounds like the usual contact is accepted.

Both describe a confirmation the fraudster controls. The change feeds the supplier master file from which every later payment is made, and the monthly review that would look for changed bank details does not yet run, so one accepted change can divert every payment until the supplier complains.

The target separates the confirmation from the request: details on file, a call-back that holds whatever the caller appears to be, and a second person who did not capture the change.

POSITION	CORE CONTROL	OWNER	FIRST RESPONSE
A core control reported as a gap	Change confirmed with supplier: partly in place; Familiar caller still verified: not in place	Finance lead	60 days (proposed)

THIRD PARTIES AND SUPPLY CHAIN

The senior review of supplier payments has been agreed but does not run

The monthly senior review is set out but not working, split orders are not yet monitored in practice, payment data is not reviewed for unusual patterns, and independent review of procurement is only partly in place.

These describe one missing capability, looking at payments as a population. It is the detective control behind the preventive ones, catching a changed bank detail that slipped through, a duplicate invoice or a split purchase. Because the design exists, the target is operational: a named reviewer outside payments processing, a monthly cycle and a first review over the last twelve months.

POSITION	CORE CONTROL	OWNER	FIRST RESPONSE
A core control reported as a gap	Senior review of supplier payments: set out, not yet operating	Finance lead	60 days (proposed)

CUSTOMERS, REVENUE AND PRODUCTS

Credit is granted on documents checked only when something looks wrong

Documents are verified only if something looks wrong, and independent approval of credit, bureau checks and the investigation of early defaults are each only partly in place. Finance could not say whether customer payments are matched to invoices.

A check triggered by appearance is the one generated payslips and statements pass. With early defaults not consistently investigated and payment matching unknown, application fraud would surface as bad debt and could repeat with the same templates.

The target verifies the key information in every application with its source before approval, and finance should establish whether payments are matched to invoices.

POSITION	CORE CONTROL	OWNER	FIRST RESPONSE
A core control reported as a gap	Application documents verified: partly in place	Finance lead	60 days (proposed)

PEOPLE, PAYROLL AND INSIDER RISK

Block leave reaches most sensitive roles, but the roles are not fully identified

Most people in sensitive roles take block leave with someone else doing their work. High-risk roles are only partly identified, avoiding conflicting duties during cover and avoiding single points of knowledge are set out but not operating, and there is no fair route for concerns or support for staff under financial pressure.

Block leave fails quietly when it misses a role, and the roles most likely to be missed are those that have grown informally around one person. Cover by someone with conflicting duties can let a scheme continue even during the leave.

The target identifies the sensitive roles, keeps the list current and requires block leave in every one, with cover by someone without conflicting duties.

POSITION	CORE CONTROL	OWNER	FIRST RESPONSE
A core control reported as a gap	Block leave required: partly in place	HR and payroll lead	60 days (proposed)

CUSTOMERS, REVENUE AND PRODUCTS

Customer refund and delivery details can be changed by sales staff

Most changes to customer details are verified, but sales staff can still make them. Defined onboarding is not in place, business customers are only partly verified, and details shared between accounts are not flagged.

The ability to change customer details is the ability to redirect refunds and goods. Moving the change out of sales and verifying it with the customer through details on file restores the separation that deters collusion. A changed record that lets an impostor see or use a customer's personal information is also a security compromise under POPIA, which section 22 requires the group to report to the Information Regulator and the customer. The response is among the first and is specified in full in the workbook.

POSITION	CORE CONTROL	OWNER	FIRST RESPONSE
A core control reported as a gap	Customer detail changes verified: partly in place	Commercial and customer lead	60 days (proposed)

PEOPLE, PAYROLL AND INSIDER RISK

Payroll is reviewed at the level of totals, and nobody could say whether its data is analysed

Someone other than the preparer looks at each run, but only at the totals; headcount verification is not in place, independent review is only partly in place, and payroll could not say whether its data is analysed.

There is no point at which the payroll is compared with the people the group actually employs, so a ghost employee or a leaver left on the payroll would not stand out. The target is a detailed review of each run before payment by someone who did not prepare it, and payroll should establish whether its data is analysed.

POSITION	CORE CONTROL	OWNER	FIRST RESPONSE
A core control reported as a gap	Payroll reviewed by another person: partly in place	HR and payroll lead	In the twelve-month programme

CUSTOMERS, REVENUE AND PRODUCTS

Refunds are approved independently only when they are large or staff are unsure

Independent approval of refunds and credit notes is sought only for large refunds or when staff are unsure. Returns are not received before credit, refund patterns and reversals are only partly reviewed, and sales could not say whether refunds go back to the original source.

A refund raised and approved by the same person below the approval threshold is one of the oldest ways to steal from a retailer, and if refunds can be paid somewhere other than the original source, the money leaves without a customer ever being involved. The target is independent approval of every refund and a rule that refunds return to the original source.

POSITION	CORE CONTROL	OWNER	FIRST RESPONSE
A core control reported as a gap	Refunds approved independently: partly in place	Commercial and customer lead	In the twelve-month programme

FRAUD EXPOSURE AND PATHWAYS

The open controls create four practised routes to loss, each hard to see from inside the process

The pathways that follow trace how the open controls could be used together: one weakness opens the route and another keeps the loss from being noticed. Each is a plausible sequence assembled from the organisation's answers and MK's scenario library, written to show management where to intervene, and none implies that the event has happened.

FRAUD PATHWAY · PEOPLE, PAYROLL AND INSIDER RISK

An employee who is never away sustains a scheme for years

A trusted employee in a sensitive role manipulates the records they control. Because the role was never identified as sensitive, block leave does not reach it, and nobody else does the work.

The scheme needs continuous attention, which the employee gives. Where leave is taken, cover by someone with conflicting duties may not see it either, and the fraud is usually found by chance, by which time it is large.

WARNING SIGNS

- An employee in a sensitive role who does not take leave
- Work that only one person understands or is allowed to do
- Queries that are always routed to the same person
- Resistance to rotation or process change

FIRST RESPONSE

Place the work with someone else immediately, review the period's transactions, and preserve the records before the employee is approached.

LASTING CONTROL

Sensitive roles are identified and recorded, and everyone in them takes block leave each year during which someone else does their work.

FRAUD PATHWAY · THIRD PARTIES AND SUPPLY CHAIN

A supplier's bank details are changed and the next payment run pays the fraudster

An outsider who has compromised a supplier's email requests a change of bank details with a contact number in the request; finance calls it and the fraudster confirms. Sometimes a follow-up call in the usual contact's voice is enough.

The next genuine invoice is paid to the new account. Every document is genuine, and with no monthly review looking for changed bank details, nothing looks wrong until the real supplier asks why it has not been paid.

WARNING SIGNS

- A bank-detail change shortly before a large or scheduled payment
- A change request that arrives by email or from a new contact
- Pressure to make the change before the next payment run
- A supplier querying non-payment after a recent change

FIRST RESPONSE

Contact the bank immediately to recall or freeze the payment, confirm the correct details with the supplier through a number already on file, suspend further payments to the changed account and preserve the request and approval trail.

LASTING CONTROL

Every change to supplier bank details is confirmed with the supplier through contact details on file before it takes effect, by someone other than the person who captured it, whatever the caller appears to be.

FRAUD PATHWAY · THIRD PARTIES AND SUPPLY CHAIN

A purchase is split below the approval limit, and nobody looks across the orders

A buyer splits a purchase into orders under the approval limit, or a supplier resubmits an invoice already paid. Each transaction passes its own checks, and the pattern exists only in data nobody examines. The loss grows with each payment run until a supplier, an auditor or a whistle-blower raises it.

WARNING SIGNS

- Several orders to one supplier just below an approval limit
- Invoices with the same amount and supplier close together
- A supplier paid more often than its contract suggests
- Orders raised and received by the same person

FIRST RESPONSE

Stop further payments on the suspect orders or invoices, recover any duplicate payment from the supplier, and preserve the order, approval and payment records.

LASTING CONTROL

A senior manager who does not process payments reviews each month's supplier payments for splitting, duplicates, unfamiliar suppliers and changed bank details, and follows up each query.

FRAUD PATHWAY · CUSTOMERS, REVENUE AND PRODUCTS

Fabricated payslips secure credit that is never repaid

An applicant presents a generated payslip and bank statement that look genuine, so the appearance-based check is never triggered. Credit is approved, goods are taken and the account defaults.

Because early defaults are not consistently investigated, the loss is booked as bad debt, and the same templates can be used again before anyone recognises the pattern.

WARNING SIGNS

- Accounts that default on the first or second instalment
- Applications with the same employer, payslip layout or contact details
- Income that is high for the goods applied for
- Pressure to approve quickly

FIRST RESPONSE

Suspend further credit on linked applications, review the other applications from the same source or template, and preserve the application files.

LASTING CONTROL

The key information in every credit application is verified with its source before credit is approved, and first-instalment defaults are reviewed for application fraud.

TARGET FRAUD-CONTROL ENVIRONMENT

The target environment verifies every change through a route the requester does not control and closes the routes insiders use

The blueprints below cover the priority controls. They share two principles: a change that redirects money, goods or credit is confirmed through details the group already holds, and no one in a sensitive role controls a process alone for long enough to conceal a fraud. The panel summarises each control's operating design; the complete specification for every control in the register, 103 in all, is in the supporting workbook.

CONTROL BLUEPRINT · TO PUT IN PLACE

Supplier bank changes confirmed through details already on file

Changes are confirmed today, but sometimes through details in the request. In the target state, every change is confirmed with the supplier through contact details already on file before it takes effect, by someone other than the person who captured it, and logged with how it was confirmed.

The control works with the call-back rule and with the monthly payment review, which looks for changed bank details among its patterns.

FRAUD SCENARIO IT ADDRESSES

Supplier payments are diverted through changed bank details

ACCOUNTABLE EXECUTIVE

Chief financial officer

PROCESS OWNER

Finance lead

POPULATION

Changes to suppliers' bank details

FREQUENCY

whenever a change is requested

SERVICE LEVEL (PROPOSED)

Completed each time, before the result is relied on; exceptions answered within the month.

INDEPENDENT CHECK

A periodic review by the fraud risk lead, who samples the records and reports exceptions.

RECORD KEPT

Bank detail change log: each request, how and by whom it was confirmed, the number used and the date the change took effect.

EFFECTIVENESS MEASURE

Every change to a supplier's bank details made in the period was confirmed with the supplier on contact details already on file before it took effect, or is a recorded and approved exception.

ESCALATION

Any case handled without the check, or any exception approved, is reported to the chief financial officer within the month.

FAILURE RESPONSE

Suspend any change to a supplier's bank details that was not confirmed until it is verified, and check whether any payment, delivery or access used it.

CONNECTED CONTROLS

Familiar caller still verified

CONTROL BLUEPRINT · TO PUT IN PLACE

A call-back rule that holds whatever the caller appears to be

A follow-up call from the supplier is accepted today. In the target state, a call back on the number on file is required for every change request, whatever an incoming call or video appears to show, and staff are briefed and tested.

Designed once for supplier changes, the same rule can protect employee bank changes, customer details and instructions from executives.

FRAUD SCENARIO IT ADDRESSES

Supplier payments are diverted through changed bank details

ACCOUNTABLE EXECUTIVE	PROCESS OWNER	POPULATION
Chief financial officer	Finance lead	Staff who process changes to supplier details
FREQUENCY	**SERVICE LEVEL (PROPOSED)**	**INDEPENDENT CHECK**
each year	Completed each year; exceptions answered before the next review.	A periodic review by the fraud risk lead, who samples the records and reports exceptions.

RECORD KEPT

Verification rule record: the rule, briefing records and the results of each test.

EFFECTIVENESS MEASURE

All staff who process changes to supplier details were briefed by the end of the period, and the most recent test found the rule followed in every case tested, including a call or video that appeared to come from the supplier's usual contact.

ESCALATION

Any exception not closed by the next review, or any review missed, is reported to the chief financial officer.

FAILURE RESPONSE

Where the rule was not followed, establish why, brief the people concerned again and check whether any payment or disclosure resulted.

CONNECTED CONTROLS

Change confirmed with supplier

CONTROL BLUEPRINT · TO PUT IN PLACE

A monthly senior review of supplier payments that actually runs

The review is agreed but not working. In the target state, a senior manager who does not process payments reviews each month's supplier payments for unfamiliar suppliers, unusual amounts, duplicates and changed bank details, and follows up each query to a recorded answer, starting with a look back over the previous twelve months.

FRAUD SCENARIO IT ADDRESSES

Procurement anomalies are never noticed

ACCOUNTABLE EXECUTIVE

Chief financial officer

PROCESS OWNER

Finance lead

POPULATION

Supplier payments

FREQUENCY

monthly

SERVICE LEVEL (PROPOSED)

Completed monthly; exceptions answered before the next review.

INDEPENDENT CHECK

Built into the control: the check is carried out by someone independent of the person whose work it covers.

RECORD KEPT

Monthly payment review: the list reviewed, the reviewer, each query raised and its answer.

EFFECTIVENESS MEASURE

The review of supplier payments ran monthly throughout the period, and every exception it raised has a recorded answer.

ESCALATION

Any exception not closed by the next review, or any review missed, is reported to the chief financial officer.

FAILURE RESPONSE

Where an exception proves to be fraud or error, follow the response procedure, correct the control that allowed it and add the pattern to the review.

CONNECTED CONTROLS

Split orders monitored; Data reviewed for unusual patterns; Independent review of procurement

CONTROL BLUEPRINT · TO PUT IN PLACE

Credit applications verified with their source before approval

Documents are checked today only on appearance. In the target state, the key information in every credit application is verified with its source before approval, and the file records what was verified and how. The control connects with independent approval of credit, bureau checks and the investigation of early defaults.

FRAUD SCENARIO IT ADDRESSES

Credit is obtained with fabricated documents

ACCOUNTABLE EXECUTIVE	PROCESS OWNER	POPULATION
Chief financial officer	Finance lead	Credit applications
FREQUENCY	**SERVICE LEVEL (PROPOSED)**	**INDEPENDENT CHECK**
before each approval	Completed before each approval; nothing proceeds while the check is open.	A periodic review by the fraud risk lead, who samples the records and reports exceptions.

RECORD KEPT

Credit application file: the information verified, the source used, the result and the date.

EFFECTIVENESS MEASURE

Every credit application in the period has a credit application file showing the key information verified with its source before approval.

ESCALATION

Any item that proceeds without the check, or any exception approved, is reported to the chief financial officer within the month.

FAILURE RESPONSE

Where a credit application went ahead without the check, complete the check at once and review anything paid or released before it was found.

CONNECTED CONTROLS

Credit approved independently; Bureau and fraud database checks; Early defaults investigated; Limit and terms changes approved

CONTROL BLUEPRINT · TO PUT IN PLACE

Block leave for every sensitive role, with independent cover

Most people in sensitive roles take block leave today. In the target state, everyone in an identified sensitive role takes a block of consecutive leave each year, with their work done by someone without conflicting duties, and exceptions are approved and recorded.

The control depends on the list of sensitive roles, so maintaining that list is part of its design, and it connects with avoiding single points of knowledge and a fair route for concerns.

FRAUD SCENARIO IT ADDRESSES

An insider in a high-risk role works unchecked

ACCOUNTABLE EXECUTIVE

Chief financial officer

PROCESS OWNER

HR and payroll lead

POPULATION

People in sensitive roles

FREQUENCY

each year

SERVICE LEVEL (PROPOSED)

Completed each year; exceptions answered before the next review.

INDEPENDENT CHECK

A periodic review by the fraud risk lead, who samples the records and reports exceptions.

RECORD KEPT

Block leave record: each person in a sensitive role, the dates of their block leave, who did their work and any approved exception.

EFFECTIVENESS MEASURE

Every person in a sensitive role in scope took a block of leave in the year with their work done by someone else, or has an approved exception.

ESCALATION

Any exception not closed by the next review, or any review missed, is reported to the chief financial officer.

FAILURE RESPONSE

Where the requirement is not met, record why, agree a corrective action with a date and report it to the accountable executive.

CONNECTED CONTROLS

High-risk roles identified; No conflicting duties when covering; No single point of knowledge; Concerns raised fairly

TARGET FRAUD-RISK OPERATING MODEL

Ownership must move into the operating areas, and every function must know the controls it owns

The group reports that executive accountability for fraud risk is written into a named role and that the board holds final oversight. The target operating model keeps both and adds owners for the controls inside the operations. The chief executive remains accountable overall; the fraud risk lead sets standards, challenges the owners and consolidates reporting; the owners of finance, payroll, customers and the other operating areas run the controls and keep the records; and the investigations lead handles reports and alerts independently.

TARGET FRAUD-RISK OPERATING MODEL

OVERSIGHT **The board**	Receives fraud risk reporting, approves the order of work and holds the executive to account. The organisation's own answer on final oversight. STATUS AND ESCALATIONS REPORTED UPWARD · DIRECTION AND DECISIONS DOWNWARD
EXECUTIVE ACCOUNTABILITY **Chief executive**	Accountable for fraud risk overall; names the accountable executives and decides the order of work. Executive accountability is reported as "Yes, it is written into a named executive's role".
COORDINATION AND CHALLENGE **Fraud risk lead**	Coordinates the fraud risk assessment, challenges the control owners and consolidates status reporting. The method's owner for fraud risk assessment.
CONTROL OWNERSHIP **Finance lead, HR and payroll lead and Commercial and customer lead**	Operate the controls in their processes, keep the records and report exceptions. The method's owners for the controls this report acts on.
DETECTION AND INVESTIGATION **Investigations lead**	Receives reports and alerts, investigates independently and records outcomes. The method's owner for detection, speak-up and response.

Roles are named by function, not by person; the assessment does not identify individuals. The chief executive's coordinating role and the fraud risk lead's challenge role are the method's owners for governance and risk assessment.

For this group the model carries a specific expectation: each control owner should be able to say how their controls operate, which is what the outstanding questions show is not yet the case. Status moves upward each month from the owners through the fraud risk lead to the chief executive and to the board at each meeting, including the questions that remain open.

The management information should keep the unknowns visible until they close. Each month the fraud risk lead should report to the chief executive the outstanding questions answered and still open, by the function that holds them, the stage reached by every open scenario, and each control measure missed or escalated. The board should see the same picture at a higher level: which functions still owe answers, which priority controls have completed a full operating cycle, and which escalations needed an executive decision. A report that shows the unknowns shrinking is itself evidence that ownership has moved into the operations.

LEADERSHIP DECISIONS

Four decisions rest with leadership, and resolving the unknowns comes first

The decisions below are those only executives can take. For each, the options and trade-offs are set out with MK's recommended route; the choice remains management's.

LEADERSHIP DECISION

How the outstanding questions will be resolved

MK recommends assigning each of the 7 questions to a named person and recording any that cannot be answered as an open item with an owner, because an answer or an owned open item is what allows the scenarios they affect to be decided.

OPTION	WHAT IT INVOLVES	EFFORT	BENEFIT	TRADE-OFF
Assign each question to a named person	Each outstanding question is assigned to one named person with a date for an answer.	Low.	Closes most gaps quickly and shows who holds the knowledge.	Some questions may reveal that nobody holds the answer, which is itself a finding.
Record as open items and proceed	Questions that cannot be answered are recorded as open items with an owner, and the work proceeds on what is known.	Low.	The programme is not delayed.	Decisions on the scenarios affected rest on incomplete information.
Establish the answer by inspecting the process	Where nobody holds the answer, the owner inspects the process and records what is found.	Moderate.	Converts an unknown into a fact.	Time from people who run the process.

MK'S RECOMMENDED ROUTE

Assign each question to a named person, and record any that cannot be answered as an open item. An answer, or a recorded open item with an owner, is what allows the scenarios the questions affect to be decided.

Decision owner: Chief executive. When: Before the scenarios they affect are ordered. If delayed: The scenarios they affect stay unknown rather than covered.

LEADERSHIP DECISION

Who will be accountable for each open area

Six areas have open scenarios. MK recommends that each operating executive owns the scenarios in their area, with the fraud risk lead coordinating the requirements that span areas.

OPTION	WHAT IT INVOLVES	EFFORT	BENEFIT	TRADE-OFF
One accountable executive per area	Each area with open scenarios has one executive accountable for its controls, as the method suggests.	Low to decide; ongoing for each executive.	Clear ownership that matches how the organisation is run.	Requirements that span areas, such as how changes to payment details are verified, need coordination across owners.
One executive for the whole programme	A single executive owns every open scenario and directs area leads.	Concentrated on one person.	One point of accountability and a consistent approach.	Area executives may treat the work as someone else's.
Area owners with a programme coordinator	Area executives own their scenarios, and the fraud risk lead coordinates requirements that span areas and reports progress.	Moderate.	Ownership stays in the areas while cross-area requirements are handled once.	Needs a coordinator with enough standing to hold owners to account.

MK'S RECOMMENDED ROUTE

Area owners with a programme coordinator. The open scenarios sit in the operating areas, so ownership belongs there; several of the requirements span areas and are best designed once.

Decision owner: Chief executive. When: Before design work starts. If delayed: Open scenarios have no owner, and the controls that stop them stay unassigned.

LEADERSHIP DECISION

The order in which the open scenarios will be addressed

The order should rest on facts management can defend. MK recommends resolving the unknowns first, then weighing each open scenario on explicit factors, and applying the shared verification requirement once wherever it arises.

OPTION	WHAT IT INVOLVES	EFFORT	BENEFIT	TRADE-OFF
Explicit factors, settled facts first	Answers to settle come first; then each open scenario is weighed on how far its control is reported in place, whether money, pay, cash or stock can leave without it, how much of the activity exists, and what management already knows of incidents.	Moderate: a structured management session.	A defensible order that management can explain to the oversight body.	Depends on information management must supply, such as volumes and known incidents.
Area by area	One area is completed before the next begins.	Low to plan.	Simple to manage and report.	Requirements that span areas are designed several times, and exposure in later areas waits.
Cross-area requirements first	Requirements that span areas, such as verifying changes to payment details, are designed once and applied everywhere, before area-specific controls.	Moderate.	One design closes several scenarios at once.	Area-specific exposures wait until the shared designs are complete.

MK'S RECOMMENDED ROUTE

Explicit factors, settled facts first, applying cross-area requirements once where they arise. An order of work should rest on facts management can state and defend to its oversight body, and designing shared requirements once avoids building the same control several times.

Decision owner: Chief executive. When: Before design work starts. If delayed: Effort is spread across every scenario at once, or follows the order of this report, which is not a ranking.

LEADERSHIP DECISION

How the board will see progress

MK recommends a one-page status for each open area at every board meeting, covering both the controls and the questions that remain open, until each is closed, deferred with a reason or accepted.

OPTION	WHAT IT INVOLVES	EFFORT	BENEFIT	TRADE-OFF
At each meeting of the oversight body	A one-page status per open scenario at each meeting until it is closed, deferred with a reason or accepted.	Low.	Keeps the scenarios visible to the people who can remove blockers.	Adds to the oversight body's agenda.
Quarterly summary	A consolidated summary each quarter.	Low.	Less frequent demand on the oversight body.	Blockers may wait a quarter before they are seen.

OPTION	WHAT IT INVOLVES	EFFORT	BENEFIT	TRADE-OFF
Exceptions only	Only scenarios that are late or blocked are reported.	Lowest.	Focuses attention on problems.	The oversight body does not see progress, and a scenario can drift without being reported as an exception.

MK'S RECOMMENDED ROUTE

At each meeting of the oversight body, until each open scenario is closed, deferred with a reason or accepted. Regular reporting is what keeps a programme moving once the first controls are in place.

Decision owner: Chief executive. When: From the first meeting after this report. If delayed: Progress is not visible until the next assessment.

TWELVE-MONTH IMPLEMENTATION BLUEPRINT

Over twelve months the programme replaces unknowns with answers and carries the framework into the operations

The programme runs in four proposed stages. The windows are proposals for management's own plan, not deadlines, contractual dates or estimates of how long any control takes to design or to prove. A control counts as working only once it has met its success measure over a full operating cycle.

THE TWELVE-MONTH PROGRAMME, IN PROPOSED STAGES

Stabilise

0 TO 30 DAYS, PROPOSED

Settle the answers, name the owners and decide the order of work.

- Outstanding questions answered or owned
- Accountable executives named
- Order of work recorded with its factors

OWNERS

Every area owner, coordinated by the fraud risk lead and reporting to the chief executive

Establish

31 TO 90 DAYS, PROPOSED

Approve the priority control designs, put them in place and run their first operating cycles.

- Change confirmed with supplier
- Familiar caller still verified
- Senior review of supplier payments
- Application documents verified
- Block leave required

OWNERS

Finance lead, HR and payroll lead

Embed

MONTHS 4 TO 6, PROPOSED

Extend to the remaining selected scenarios and strengthen the further defences, with regular reporting.

- Remaining selected controls put in place
- Related practices strengthened
- Monthly status reporting running

OWNERS

Every area owner, coordinated by the fraud risk lead and reporting to the chief executive

Mature

MONTHS 7 TO 12, PROPOSED

Measure each control over a full cycle, refresh the scenarios and report to the oversight body.

- Each control measured over a full cycle
- Scenarios refreshed against the assessment
- Status reported to the board at each meeting

OWNERS

Every area owner, coordinated by the fraud risk lead and reporting to the chief executive

Windows are proposals for management's own plan. They are not deadlines, contractual dates or estimates of how long any control takes to design, put in place or show to be working. Every action, with its deliverable and completion test, is in the supporting workbook.

Stabilise resolves the outstanding questions or gives each an owner, names the accountable executives, records the order of work and approves the designs, beginning with the shared verification standard. Establish puts the priority controls in place and runs their first cycles.

Embed extends the work to the remaining open scenarios in the order management has decided, informed by the answers obtained in the first stage, and strengthens the related practices. Mature measures each control over a full cycle, arranges the independent examination of procurement and payroll, refreshes the scenarios and reports to the board. Every action is in the supporting workbook.

MANAGEMENT FRAUD-READINESS SCORECARD

The scorecard shows whether the controls work and whether the unknowns are closing

Each control measure describes what its records should show once it operates; the programme measures track the response itself. None is reported as met today.

MANAGEMENT FRAUD-READINESS SCORECARD

MEASURE	OWNER	FREQUENCY	ESCALATION THRESHOLD
Every change to a supplier's bank details made in the period was confirmed with the supplier on contact details already on file before it took effect, or is a recorded and approved exception.	Finance lead	whenever a change is requested	Any case handled without the check, or any exception approved, is reported to the chief financial officer within the month.
All staff who process changes to supplier details were briefed by the end of the period, and the most recent test found the rule followed in every case tested, including a call or video that appeared to come from the supplier's usual contact.	Finance lead	each year	Any exception not closed by the next review, or any review missed, is reported to the chief financial officer.
The review of supplier payments ran monthly throughout the period, and every exception it raised has a recorded answer.	Finance lead	monthly	Any exception not closed by the next review, or any review missed, is reported to the chief financial officer.
Every credit application in the period has a credit application file showing the key information verified with its source before approval.	Finance lead	before each approval	Any item that proceeds without the check, or any exception approved, is reported to the chief financial officer within the month.
Every person in a sensitive role in scope took a block of leave in the year with their work done by someone else, or has an approved exception.	HR and payroll lead	each year	Any exception not closed by the next review, or any review missed, is reported to the chief financial officer.
Outstanding questions answered by the function that holds them	Chief executive	each month until closed	A question still unanswered after 30 days is assigned to a named person and reported.
Open scenarios with a named owner and a recorded decision to address, defer or accept them	Chief executive	each month	A scenario without an owner after 60 days is reported to the oversight body.

MEASURE	OWNER	FREQUENCY	ESCALATION THRESHOLD
Priority controls that have met their success measure for a full operating cycle	Fraud risk lead	each quarter	A control that misses its measure twice is reported with its owner's correction plan.
Status reported to the board	Chief executive	each meeting	A missed report is itself reported at the next meeting.

Control measures describe what each control's records should show for a period once it operates; programme measures track the response itself. None is reported as met today.

For this group the first measure to watch is the number of outstanding questions answered by the function that holds them, because it shows whether the operating functions have taken ownership. The second is whether the priority controls have met their measures over a full cycle.

METHODOLOGY AND LIMITATIONS

The position rests on the organisation's own answers, read together against MK's method

Answers are read against MK's method of fraud scenarios and controls, and together as well as one at a time. Answers given as "not known" or declined are reported as outstanding and never as weaknesses.

The executive diagnosis states the position in four parts: the calculated result, the answers that are inconsistent, the reading of the answers and MK's conclusion. Material findings, blueprints and stages are chosen and sequenced by the rules stated where each appears, not by a ranking of fraud risk.

PROTOTYPE NOTICE: WHAT A RELEASED REPORT ADDS

ELEMENT	IN A RELEASED REPORT	IN THIS EDITION
Readiness conclusion	Issued under MK's approved readiness method, with the score and level that method defines.	Calculated result shown as a labelled test fixture; no level or band issued (decision D-1).
Order of work	Set by MK's approved decision method.	Ordered by the explicit factors stated in the report, a candidate method (decision D-3).
Control specifications, pathways and decision options	MK-approved advisory content.	Draft content from MK's control-content library, scenario structures and decision options (decision D-5).
Manuscript	Written by the production AI writer from this fact pack, then validated.	Written in-session under the same writer contract and validated by the same checks; the production AI run is a blocked acceptance test.

MANAGEMENT CONCLUSION

Within a year the group should know how its controls work and have carried its framework into the operations

The group should recognise two things. Its fraud programme is complete at the centre and largely absent in the operations, and several of the functions that run those operations cannot yet say how some of their own controls work. The first is a gap in controls; the second is a gap in knowledge, and it has to be closed first.

The transition required starts with answers and ownership: every outstanding question resolved or owned, and every operating area with an accountable executive. On that foundation, a single verification standard should protect every change that redirects money, goods or credit, the monthly review of supplier payments should run, sensitive roles should be identified and covered by block leave, and someone independent should look across procurement and payroll.

By ninety days, the unknowns should be resolved or owned, the owners named and the priority controls running their first cycles. By twelve months, those controls should have met their measures over a full cycle, the remaining scenarios should be in progress in the order management decided, and the board should be receiving status it can rely on.

MK Advisory would add value once the first controls are running, to examine whether they operate as designed and to support the independent review of procurement and payroll, which call for the records and walkthroughs that this assessment does not include.

Fraud strategy, readiness and operational resilience.

info@mkfraud.co.za
www.mkfraud.co.za

This report was prepared for the management of Fictional Retail Group (extensive unanswered information) on the basis of the organisation's own answers to the MK Fraud Readiness assessment. It is confidential to the organisation. MK Fraud Insights is a trading name of Stonda (Pty) Ltd. Fictional prototype for MK review; not a customer report.